2026（第八届）FinTechathon 深圳国际金融科技大赛

微众银行金融科技大学生挑战赛　国内人工智能赛道

TROPOS

安全自评报告

TROPOS 自适应银行智能体

安全自评报告

团队	咪咪大王队 刘水、余冠辰（复旦大学经济学院）
编号	TROPOS-SSR-3.2.9
赛题	AI 代人操作银行（安全与体验）
日期	2026 年 11 月 2 日

TROPOS 自适应银行智能体

安全自评报告

咪咪大王队
刘水、余冠辰（复旦大学经济学院）

TROPOS-SSR-3.2.9
安全自评报告　系统版本 3.2.9　修订版 2.0
2026 年 11 月 2 日

摘要

TROPOS 面向自然语言办理银行事务，将安全控制嵌入身份识别、财务读取、方案生成、用户确认与执行反馈的全过程。本报告基于 3.2.9 版本代码与测试证据，对权限分级、账户隔离、金融操作、模型与外部服务、网络部署进行自评，展示项目在安全与体验之间的设计取舍。

项目已实现注册账户隔离、分场景读取同意、转账方案确认与事务记账，并对模型输入输出和外部连接器建立控制边界。自动化测试覆盖身份、业务、客户端及规则模式下的对抗场景，为持续迭代提供回归依据。银行账本与回执采用合成数据；美团跑腿链路可能涉及真实个人信息、订单与用户自行完成的支付。

本报告为项目组自评，结论适用于所述演示范围；安全测试结果不能替代独立测评。有关网络部署和功能边界的改进事项列于报告末尾。

关键词　安全自评；分级授权；用户确认；账户隔离；数据保护。

评估基线　系统版本 3.2.9；后端基线 2a33063；测试记录与复核范围见第 11 节。

目录

1　评估结论 **3**

2　评估范围与方法 **3**

3　系统资产与数据分级 **3**

4　信任边界与数据流 **4**

5　权限分级与授权链 **4**

5.1　分层设计 4

5.2　从意图到确认 4

6　认证、会话与账户隔离 **5**

7　金融操作安全 **5**

7.1　关键控制 5

7.2　多步骤任务 5

8　模型与外部服务安全 **5**

8.1　模型密钥与数据 6

8.2　输出校验与降级 6

8.3　邮件与账户恢复 6

9　美团授权与地址数据 **6**

10　部署与网络防护 **6**

11　安全测试证据 **7**

12　已知风险与整改优先级 **7**

13　结论与适用声明 **8**

1. 评估结论

TROPOS 以“用户知情、动作可控、结果可追溯”为安全设计原则，将身份认证、数据读取、方案确认和服务端记账组织为相互衔接的控制环节。对于自然语言提出的金融需求，系统先形成可检查的方案，再由用户确认，服务端依业务路径执行校验并返回结果，让智能体的便利性建立在清晰的权限边界之上。

项目已在合成银行沙箱中实现账户分区、确认凭证、幂等记账、模型输出校验及外部服务状态隔离等措施。注册用户与共享演示身份具有不同的隔离边界；真实外部服务的数据与支付边界也独立于模拟银行账本。本次自评支持比赛演示与技术验证，并为后续安全加固明确方向。

> **评估声明** 本报告是项目组对代码和已有测试结果的自查，不是第三方认证。当前系统不接入真实银行资金，不提供真实信贷或投资决策；接入真实客户和金融业务前仍需完成部署加固、独立评估及相应机构对接。

2. 评估范围与方法

评估覆盖 Web 前端与 HTTP 网关、身份与会话、合成账本、生活规划与多步骤任务、模型中心、邮件和美团连接器，以及仓库中的部署配置。外部银行核心、供应商内部安全和生产级灾备不在本次验证范围内。

本次以原安全自评报告为基础，对照服务端代码与现有测试记录，梳理资产、信任边界和主要操作链；结合独立只读代码复核，将已实现控制、测试证据和需进一步完善的事项分开表述。已有测试反映运行时快照，并非对所有当前部署环境的验证。

3. 系统资产与数据分级

类别	主要资产	保护重点
机密凭证	密码、模型 API Key、美团授权材料、TOTP 相关密钥	减少暴露，限制访问与保留；供应商密钥用于请求认证
身份与联系	会话令牌、用户名、邮箱、手机号、地址	按会话与用户边界访问，注意外部服务所需的数据传递
财务与画像	合成余额、流水、计划、画像、方案与回执	依用户身份和业务权限读取，维护变更记录
公开内容	页面、术语与公开演示信息	保持可访问性与完整性

数据处理遵循按功能取用的原则，但不将“字段裁剪”等同于完全匿名：用户输入的自由文本和自定义内容仍可能包含个人信息，需要结合外部服务的实际用途管理。

4. 信任边界与数据流

浏览器向服务端提交请求和会话凭证；服务端识别用户并处理授权、账本和业务规则；模型供应商、邮件服务与美团连接器位于独立的外部服务边界。每次跨越边界的数据范围取决于所选功能和服务配置。

用户消息、历史对话、商户信息及外部返回均应视为不可信输入。项目通过结构校验、业务规则与用户确认降低模型输出直接影响账本的风险；这些措施不能保证消除所有提示注入或错误建议。

5. 权限分级与授权链

5.1 分层设计

层级	主要能力	适用边界
访客	浏览公开页面与健康状态	不凭访客身份读取其他用户账本
共享演示	使用 A/B/C 合成演示身份	同一 persona 可由多位演示者共用，不适合存放个人隐私
注册账户	登录并使用自己的账户与设置	服务端根据会话识别用户；注册时复制合成样例
读取同意	财务体检、相关分析与模型财务上下文	相关业务检查读取同意；账户基础快照另有其返回路径
动作确认	查看方案后确认特定变更	具体令牌、校验与重试机制依操作类型而异
部署配置	管理运行环境与平台模型配置	在线模型配置默认关闭；开启开关本身不等于管理员身份认证

5.2 从意图到确认

系统通过会话确定用户身份；在相关功能中检查读取同意；生成待确认方案后，再依具体操作核对所属用户、确认凭证、有效性与业务约束。常规转账路径具有方案绑定

的确认令牌、状态与财务复核，以及事务和重试处理。不同类型的订阅、多步骤任务和外部订单各有自己的执行契约，不应简单视为完全相同的确认流程。

6. 认证、会话与账户隔离

注册账户使用独立用户标识与独立账本，初始 A/B/C 样例为复制而非共享后续交易数据；共享演示入口则复用对应 persona，适合公开演示但不适合真实个人资料。账户相关对象按用户标识进行查询和管理。

密码采用带随机盐的 scrypt 派生；会话使用随机令牌，服务端保存摘要并设置有效期。登录流程包含失败限制；系统支持邮箱验证、密码重置与 TOTP 多因素认证，密码重置后撤销旧会话。这些机制改善演示系统的身份保护体验，不能替代真实银行业务所需的实名与设备风控。

7. 金融操作安全

7.1 关键控制

常规转账将方案生成与确认执行分离：用户先查看收款人、金额和财务影响；服务端确认时检查方案归属、确认令牌、状态、有效期、版本与相关财务约束。金额以整数分处理，记账与回执在事务中保存；针对已结算方案的重试返回既有结果，以减少重复执行风险。

模型用于理解需求、辅助解释和形成待核验的候选方案；金融动作是否执行由服务端业务路径和用户确认决定。模型输出及用户输入仍需经过业务字段、金额与对象等检查，不能将模型的文字描述当作实际交易回执。

7.2 多步骤任务

复合任务将多个动作组织为有序步骤，展示计划与影响，并通过任务确认请求决定本次允许执行的步骤。业务失败可能暂停后续步骤，之前已成功的步骤和回执会保留；数据库异常回滚与业务上部分完成是不同情形。部分操作的执行时复核仍需进一步统一，见第 12 节。

8. 模型与外部服务安全

8.1　模型密钥与数据

平台模型配置默认不开放在线修改。个人模型密钥按用户保存在服务进程内存，重启后清除；调用外部服务时，密钥用于所配置端点的身份认证。启用运行时平台模型管理后，具备有效会话的用户可能修改共享配置，因此只适合完全可信的演示环境。

外部模型可能接收用户当前消息、有限历史及经授权的财务汇总；系统不主动将完整原始账本、内部用户标识或会话令牌作为模型上下文附加，但用户自行输入的敏感信息可能随消息发送。自定义模型端点的控制者也会接收发往该端点的内容和认证信息。

8.2　输出校验与降级

系统对模型候选输出进行结构与业务检查，并在相应只读场景提供本地规则回退。提示注入、模型幻觉和第三方服务变化仍需持续评估；安全依赖服务端约束与用户确认共同发挥作用，而非仅依赖提示词。

8.3　邮件与账户恢复

邮件验证和密码找回使用限时挑战。配置 SMTP 时，收件地址和邮件内容由邮件服务处理；未配置时，本地演示 outbox 可能保存含验证链接的文件，应保护其访问权限并按需清理。

9.　美团授权与地址数据

美团官方连接器与模拟购物分别处理：部分购物流程使用模拟数据，真实跑腿能力依赖单独部署的官方组件与用户授权。真实询价和订单可能向美团传送姓名、手机号、地址、坐标和物品需求；支付在美团页面由用户自行完成，不扣减 TROPOS 的合成银行账本。

连接器按用户划分状态目录，调用外部程序时使用参数数组；该隔离不等同于操作系统沙箱，上游工具可能缓存授权材料。手动地址令牌使用签名保护完整性，编码本身不提供加密，相关信息应按敏感数据管理。真实订单创建不等于支付成功或履约完成。

10.　部署与网络防护

项目提供反向代理及容器化配置，包含请求格式与长度限制、常见安全响应头，以及最小权限等部署措施。具体保护效果取决于实际配置、代理转发与运行环境；代理对请求头的改写也会影响后端看到的来源信息，不能仅凭配置文件认定线上已正确部署。

当前局域网访问口令的判断依赖请求中的 Host 值：静态代码复核显示，直接访问服务的客户端可能伪造回环 Host，从而绕过该口令检查。该发现尚未经网络动态复现，但

足以要求在开放局域网演示前优先修正并验证；在完成修正前，应限制服务仅供可信本机访问。

11. 安全测试证据

项目对主要功能开展了自动化回归，并对典型对抗输入设置正常对照。以下为 2026 年 11 月 2 日在本地工作区运行所得记录；后端与测试代码相对基线 2a33063 无后续差异，界面存在单独更新，前端结果归属于测试时快照。

验证项目	记录结果	说明
Python 自动化测试	共 470 项；469 通过，1 跳过	包含身份、账本、模型替身和连接器等；跳过项为 Windows 专属测试
Node 自动化测试	101 项通过	覆盖客户端与工作台等代码，非真实用户浏览器验收
规则模式对抗回归	62/62 样本达到预期	项目组编写的合成样本，未调用真实模型
正常对照	14/14 达到预期	防止仅以禁用全部正常流程获得拦截结果

测试记录见随附源码包 evidence/。对抗集不是独立留出集，结果不能解释为未知攻击拦截率；本次不声称完成独立渗透测试、真实模型全面安全测试或真实订单端到端验收。

12. 已知风险与整改优先级

项目已为演示场景建立多层控制，以下事项是迈向更广泛使用时的重点改进方向：

1. **优先加固网络访问。**修正局域网口令对 Host 的信任，基于可靠连接来源或统一鉴权校验，并增加针对伪造 Host 的回归测试。
2. **完善管理与账户边界。**为平台模型配置增加独立管理权限；继续明确共享演示身份的使用提示，避免输入真实个人数据。
3. **统一多步骤执行检查。**对理财等动作在执行时重新检查持仓状态与限制，覆盖同一任务连续操作的情况；明确部分完成状态与回执。
4. **深化数据与供应链治理。**完善外部模型、邮件和美团的数据提示、保留策略和密钥保护；核验外部组件的授权、完整性及更新。

5. **为真实业务补齐基础设施。**如未来考虑真实客户或资金，需先引入持牌机构身份与交易风控、托管密钥、集中审计、备份恢复、供应商协议及独立安全评估。

13. 结论与适用声明

TROPOS 3.2.9 将用户意图理解与确定性业务控制结合，在合成银行沙箱中构建了从身份、读取授权到方案确认、交易回执的安全设计。多场景自动化回归为项目迭代提供了可复查的基础，也体现了项目对可控、安全且易用的智能体体验的重视。

现阶段适用于使用合成银行数据的比赛演示、教学和技术研究。美团等外部功能具有独立的数据和支付边界，应由使用者知情选择。随着网络入口、管理权限与多步骤校验等事项持续完善，项目可为下一阶段的独立评估和机构合作积累基础。